An Identity and Physical Access Laboratory with Departmental Operations

Laboratory Team
Generic working copy without personal or institutional information

***Abstract*—This document describes an executable laboratory combining physical access, identity management, local surveillance and departmental operations. OneLogin provides OpenID Connect authentication and SCIM provisioning. A Flask application checks current account status and permissions before changing its persistent laboratory resource. Frigate stores video from phone cameras. Separate tools record requests, collect RFID events and reconstruct timelines. Thirty-six local automated checks passed during development. Cloud integration, the RFID hardware and continuous recording require validation in the actual laboratory. This working report must be completed with measured integration results before final submission.**

***Index Terms*—identity management, physical access, OneLogin, SCIM, surveillance**

I. Introduction

The exercise models a restricted computing area whose users must pass a physical access check and authenticate before performing a permitted task. The project organizes 31 generic positions into Direction, Human Resources, Information Technology, Identity and Access Management, Security Operations, Physical Security and Audit. Personal assignments remain in an external private record.

II. Architecture

RFID decisions are made by the microcontroller, which reports an explicit entry or exit event to a laptop. Four authorized laboratory profiles are configured using local UID values. The provided electrical example is specific to Arduino Uno and MFRC522; it is not validated for unidentified hardware.

Phone cameras send MJPEG or RTSP streams to a virtual Frigate NVR. The configuration uses continuous recording and an authenticated local interface. Actual addresses, stream paths and credentials must be configured locally. The application tunnel provides external HTTPS reachability for OneLogin and does not expose the NVR.

OneLogin authenticates the user using OIDC and provisions the local application account using SCIM Core 1.0[1], [2]. The application requires the authenticated email to match an active provisioned account and binds the provider subject. It rechecks the current database role on each protected action. Microsoft 365 administration is a separate workstream; this design does not federate or synchronize the two identity systems.

III. Implementation

A. Application resource

The resource stores a maintenance counter, last maintenance timestamp and availability mode in SQLite. A maintenance user can read and increment the counter. An administrator can change the mode. Audit and SOC users can inspect logs and the hub without receiving mutation privileges. POST operations require a session CSRF token. Deactivation, deletion or role change affects subsequent protected requests from an existing session.

B. Departmental workflow

Direction maintains milestones and generic positions. Human Resources tracks requests, owner approval and closure with evidence references. The local request tool checks different operators and resource ownership, but does not authenticate CLI operators. Its control relies on the designated operator and private approval process; OneLogin controls application identity.

IT receives runtime preparation, Docker deployment and TCP connectivity tools. A PowerShell helper supports Microsoft Graph account creation, modification, password reset, license assignment, blocking, session revocation and audit queries[4]. Its cloud operations require authorized tenant access and have not been executed during local development.

SOC exports application events, normalizes timezone-aware timestamps and joins them with RFID events using an explicit laboratory identifier. This establishes a reviewable sequence, not causal proof. Video and OneLogin/Microsoft logs are reviewed alongside that sequence. Audit generates evidence hashes and executes local suites; hashes detect changes but do not establish that a functional test passed.

IV. Local Verification

Development executed seven storage/permission tests, six publication-guard tests and 23 application/operations tests, totaling 36 passing checks. HTTP tests covered anonymous SCIM rejection, duplicate users, malformed payloads, CSRF, persistent mutations, denied roles, existing-session revocation and identity binding. Operations tests covered owner approval, self-approval rejection, UTC ordering, HTML escaping, evidence hash changes and runtime separation.

Provider responses are mocked only in identity-binding unit tests. Those tests do not validate a real OneLogin token, MFA challenge, tenant provisioning configuration, Docker runtime, camera stream or microcontroller. The repository CI separately runs the suites and builds the application image; its result should be recorded from the actual workflow run.

V. Integration Results to Complete

The following observations are pending laboratory execution. Replace this section with measured results and private evidence references; do not label them successful in advance.

1) OneLogin: real OIDC login, MFA challenge, automatic creation, role update and deprovisioning.
2) RFID: four permitted cards, one rejected card, explicit direction and correspondence with video.
3) NVR: both phone streams, recording without movement, playback, mobile access and recovery after restart.
4) Continuity: actual duration, missing intervals, power availability and disk consumption; a retention setting alone does not prove 24-hour operation.
5) Microsoft 365: user changes, password policy, license, roles, MFA, audit/alert review and account retirement within available licenses.
6) Integrated scenario: approved engineer entry, permitted maintenance, denied auditor mutation, logout, exit and retirement of access.

VI. Limitations and Conclusions

The deliverable provides tested local logic and executable deployment/configuration materials. Hardware identification and cloud permissions remain dependencies. The adaptation of legacy video transceivers must be documented with the evaluator's accepted approach. The final report must identify failed or unavailable capabilities, record time and evidence for each integration check, and avoid presenting synthetic or configuration-only results as observed performance.

References

[1] OneLogin, "Connect an OIDC application," https://developers.onelogin.com/docs/openid-connect/connect-to-onelogin/.

[2] OneLogin, "Implement SCIM APIs," https://developers.onelogin.com/docs/scim/implement-scim-api/.

[3] Frigate, "Recording configuration," https://docs.frigate.video/configuration/record/.

[4] Microsoft, "New-MgUser," https://learn.microsoft.com/en-us/powershell/module/microsoft.graph.users/new-mguser.